deedglass

Full scan report

Sample, from the Deedglass demo

`~/acme-store · 2026-10-05 · scan sha256:dd3d…6fc2 · config and database checked · Blast radius: C`

Your agent can change 5 tables in acme and use 5 write tools.

5 tables can lose rows in a way undo can't put back.
6 write paths reach the database with no policy and no person in between.

C 72 of 100 · deductions

security_definer_...	−8	public.products	−4
public.customers	−4	public.refunds	−4
public.order_items	−4	orders-direct.ex...	−0
public.orders	−4		

A means a small blast radius, not a safe agent.

What the agent can change

Add: a numbered policy below, or wrap (put the tool behind deedglass mcp wrap)

Tool or table	Can change	Worst single call	Undo?	Today	Add
`orders-direct.execute_sql`	*not checked*	*not checked*	*not checked*	Not routed	`wrap`
`3 tools on orders, scratch`	*not checked*	*not checked*	*not checked*	✓ Through the Gate	
`public.orders`	every row	TRUNCATE, about 500 rows; UPDATE fires orders_ship_open_batch	Can't be undone	No approval	`1, 2`
`public.order_items`	every row	TRUNCATE, about 1,250 rows	Can't be undone	No approval	`1`
`public.customers`	every row	TRUNCATE, about 120 rows	Can't be undone	No approval	`1`
`public.refunds`	every row	TRUNCATE, about 60 rows	Can't be undone	No approval	`1`
`public.products`	every row	TRUNCATE, about 40 rows	Can't be undone	No approval	`1`

Three policies to add first

Core lines; deedglass scan --format md writes each one in full

1 DROP and TRUNCATE never run, whatever the agent sends.

```
- id: block-destructive-sql
  match: { connector_type: postgres }
  when: sql.kind in ["drop", "truncate"]
  decision: deny
```

2 Writes to public.orders wait for a person.

```
- id: writes-need-approval
  match: { tool: postgres.execute }
  when: sql.category == "write" && "public.orders" in
sql.tables
  decision: require_approval
```

3 More than 60 calls a minute from one agent waits for the next minute.

```
- id: agent-rate
  window: minute
  max_calls: 60
```

What this scan looked at

- 15 files in ~/acme-store
- 1 MCP client config, 4 servers in them
- Postgres 18.6 as acme_owner: grants, triggers, row security and definer functions, 6 tables

What it didn't look at

- Each MCP server's own code: tools are graded from a catalog.
- The rows in your tables: it never reads data.
- What your agent will do: it grades what the setup allows.